

T02 — Rules of Engagement

[ENGAGEMENT NAME] — [CODE NAME]

Engagement reference

[RT-YYYY-NNN]

Code name

Classification

Version

Assessed organisation

Assessing organisation

Mandating authority, where applicable

Execution period

From _____ to _____

Date of issue

These Rules of Engagement govern the whole engagement and shall be observed throughout execution. A restriction, suspension or stop instruction takes effect immediately and is recorded as soon as practicable. Any expansion of target space, action, objective, capability or risk requires prior written approval from every authority affected. These Rules shall be amended whenever an authorised boundary changes.

Produced to the standard at Annex B of the Red Team Methodology.

Summary

Objectives

Objective ID

Objective

O-01

O-02

O-03

Principal restrictions

Restriction

Restriction

Authorised target space, in summary

Target-space summary

Cessation. Contact [TRUSTED AGENT] on [24-HOUR NUMBER]. Code word: [CODE WORD].

1. Introduction

1.1 Purpose

These Rules of Engagement establish the relationship and obligations between the red team, the system owner and the assessed organisation for the engagement named above.

1.2 References

- a. Red Team Methodology, version [X.Y].
- b. Letter of Authorisation dated [DATE].
- c. [OTHER REFERENCES]

1.3 Scope of this document

Applies to all activity conducted by the personnel named at Appendix 2 against the target space at Appendix 3 during the execution period.

1.4 Definitions

As set out in the Lexicon to the Red Team Methodology.

2. The engagement

2.1 Category

☐ SL-1 Internal assessment ☐ SL-2 Mandated engagement ☐ SL-3 Exercise ☐ SL-4 Purple team

2.2 Attributes

Attribute	Value
Covert or open	☐ Covert ☐ Open ☐ Partially covert:
Starting posture	☐ External ☐ Assumed breach, user ☐ Assumed breach, server ☐ Insider ☐ Supply chain
Capability level emulated	☐ 1 Opportunistic ☐ 2 Targeted criminal ☐ 3 State-aligned ☐ 4 Insider-enabled
Social engineering authorised	☐ Yes ☐ No
Physical entry authorised	☐ Yes ☐ No
Execution period	_____ working days

2.3 Objectives

Objective ID	Objective	Assessment objective	Verification	Standard of evidence	Prohibited proof
O-01					
O-02					
O-03					

2.4 Methodology

Conducted in accordance with the Red Team Methodology, using the Get In, Stay In, Act model. The stages are at Chapter 7, paragraph 7.8, of that publication.

2.5 Activity types

The following categories of activity are permitted within the authorised target space.

☐ Passive reconnaissance ☐ Active enumeration ☐ Identification and exploitation of weaknesses ☐ Social engineering ☐ Credential access and reuse ☐ Privilege escalation ☐ Lateral movement ☐ Persistence ☐ Command and control ☐ Demonstration of data access ☐ Physical entry ☐ Other: _____

2.6 Equipment and software

Command and control framework
Platforms
Principal tooling
Infrastructure providers
Source addresses
See Appendix 3

2.7 Threat profile

Adversary emulated

Basis

☐ Named group ☐ Composite

Capability level

Full profile

Appendix 8

3. Appointments

Appointment	Name	Organisation	Authority
Approving Authority			Accepts operational risk; countersigns the Letter of Authorisation where different from the System Authority
System Authority			Consents to access to the systems and facilities identified in Appendix 3
Trusted Agent			Unilateral authority to suspend or terminate at any time
Control Team			Supports the Trusted Agent; staffs the deconfliction line
Red Team Lead			Conduct and safety of the engagement; may suspend at any time
Operators			Execute within these Rules of Engagement
Legal adviser			Advises on authorisation and data protection

Contact details at Appendix 2.

3.1 Independence and reporting safeguards

Safeguard	Engagement-specific record
Function and chain of command being assessed	
Approving Authority independence and any declared conflict	
Red Team Lead's direct reporting route to the Approving Authority	

Safeguard

Engagement-specific record

Final report recipients and simultaneous issue time

Factual-accuracy process; no right to suppress or silently amend findings

Route for a written management response or severity dispute

Independent threat-profile and report reviewers

4. Conduct

4.1 Standing instructions

Operators conduct activity in accordance with Chapter 8 of the Red Team Methodology, which is incorporated by reference. Technique approval levels are at Annex E, paragraph E.2.3.

4.2 Additions particular to this engagement

- a.
- b.

5. Deconfliction

5.1 Procedure

- a. The Trusted Agent, or a member of the defensive element through the Trusted Agent, contacts the Red Team Lead on the deconfliction line, stating the time in UTC, the source address, the target, and the behaviour observed.
- b. The Red Team Lead suspends activity in the affected area.
- c. The Red Team Lead examines the operator, infrastructure and session records and responds within the period below.
- d. The determination is definitive. Where the records do not establish attribution to the red team, the determination is that the activity is not attributable, and it is handled as a genuine intrusion until established otherwise.
- e. The exchange is recorded on pro forma T07.

5.2 Parameters

Deconfliction line, answered continuously

Alternate

Response period _____ minutes (default 30)

Code word [CODE WORD]

Maximum interval without contact with the Trusted Agent _____ hours (default 4)

Authority to resume Trusted Agent, in writing

5.3 Genuine intrusion

Where evidence of a genuine, unrelated intrusion is identified, the procedure at Annex E, paragraph E.5.5, applies. Activity ceases, the Trusted Agent is notified by telephone using the code word, evidence is preserved, and the activity record is transferred. The red team does not investigate or remediate. Resumption requires the approval of the Approving Authority.

6. Cessation

Activity ceases immediately, and the Trusted Agent is notified by telephone, on any criterion at Chapter 8, paragraph 8.15, of the Red Team Methodology, which is incorporated by reference.

Additional criteria for this engagement:

a.

Any operator, the Red Team Lead, the Trusted Agent or the Approving Authority may require cessation. No justification is required and none shall be sought.

7. Communications

Channel	Purpose	Parties	Frequency
Deconfliction line	Cessation and deconfliction	Red Team Lead and Trusted Agent	Continuously during execution
Situation report	Status	Red Team Lead to Trusted Agent	Daily, at close of day
Steering	Progress and decisions	Red Team Lead, Trusted Agent, Approving Authority	Weekly
Emergency	Suspected loss of service or genuine intrusion	Any party to the Trusted Agent	Immediate, by telephone

Where the engagement is covert, engagement communications use the following channels, outside the monitored infrastructure of the assessed organisation: _____

8. Data handling

Evidence repository

Encryption

Access control

Time standard

Coordinated Universal Time

Approved time source and tolerance

Evidence identifier scheme

Approved hash algorithm

Maximum sensitive data that may be accessed

Prohibited data

Captured credentials

Held hashed or truncated; destroyed at closure

Retention period

_____ months

Method of destruction

Classification of engagement material

9. Products

Product	Recipient	Timing
Situation report	Trusted Agent	Daily
Activity record	Trusted Agent	At culmination
Cleanup attestation	Trusted Agent	At culmination
Draft report	Trusted Agent	_____ days after execution
Report	Distribution below	_____ days after execution
Command brief	Approving Authority	With the report
Technical debrief	Defensive element	Before the report is issued

Distribution of the report (named individuals or named appointments only):

10. Legal, authority and provider conditions

10.1 Applicability and authority record

Item	Decision / reference
Applicable law, regulation, mandate and contract	
Applicability decision and responsible adviser	
System Authority and basis of authority	
Approving Authority and risk authority	
Lawful basis for processing personal data	
Controller, processor or joint-controller roles	
Data-protection impact assessment required?	☐ Yes ☐ No — reference:
International transfer or localisation conditions	
Notification or consultation obligations	
Date and author of legal/privacy review	

10.2 Provider and third-party permission register

One row for each hosted, managed, shared, supplier or other third-party service that is a source, target or material dependency. Attach the permission or policy evidence.

Provider / party and service	Account / tenant / project	Source, target or dependency	Permission / policy reference and version	Conditions / notice	Owner	Expiry	Last rechecked (UTC)

11. Limitations

- a. This engagement provides assurance only in respect of the target space, techniques and period defined herein. The absence of a finding is not evidence of the absence of weakness.
- b. The engagement emulates the capability level stated at paragraph 2.2 and does not represent the capability of every adversary.
- c. Techniques excluded on grounds of safety or legality are listed at Appendix 6. An adversary unconstrained by those limits may achieve outcomes not demonstrated here.

12. Change control

Changes follow Annex B, paragraph B.8. Restrictions and stop instructions take effect immediately. Changes extending the target space, authorising an action classified as conditional, raising capability or increasing risk require prior written approval from the Approving Authority, System Authority and any other affected authority. Absolute prohibitions cannot be changed within an engagement. All changes are recorded at Appendix 9.

13. Approval

These signatures record the agreed authority, consent, risk acceptance and constraints. Together with the Letter of Authorisation, they permit only the named personnel, positively identified target space, authorised actions and execution period. They do not replace applicable law, third-party permission or provider conditions.

Name and rank	Signature	Date
Red Team Lead		
Trusted Agent		
Approving Authority		
System Authority (<i>dual-role authority may annotate both rows</i>)		

APPENDIX 1 — IDENTIFICATION OF THE ASSESSED ORGANISATION

Legal name
Divisions in scope
Principal address

Additional sites in scope

Identifiers: domains, network numbers, tenancies

Senior contact

APPENDIX 2 — CONTACTS

Appointment	Name	Mobile	Alternate	Email	Hours	Verified
System Authority						
Approving Authority						
Alternate						
Trusted Agent						
Alternate						
Red Team Lead						
Alternate						
Legal adviser						
Out-of-hours escalation						

Every contact shall be verified by telephone within twenty-four hours before commencement.

Verification conducted by: _____ Date: _____

Operators authorised for this engagement

Name	Appointment	Confirmed reading of these Rules	Date

APPENDIX 3 — AUTHORISED TARGET SPACE

Only the positively identified systems, ranges, tenants, identities, people and locations below are authorised. Exclusion lists clarify this outer boundary but do not create it. Names, ownership assumptions, shared branding and technical reachability do not establish scope. Any ambiguity is outside scope until approved in writing.

3.1 Networks and addresses

Type	Value	Notes
Address ranges		
Domains		
Tenancies and subscriptions		
Applications		
Identity providers		

3.2 Identities and personnel groups

Group	Approximate size	Notes

3.3 Physical locations

Site	Areas authorised	Notes

3.4 Red team source addresses

Provided to the Trusted Agent for deconfliction. Not disclosed to the defensive element in a covert engagement.

Address or range	Purpose	Tier

APPENDIX 4 — EXCLUDED TARGET SPACE

Produced by the assessed organisation and confirmed by the owner of each excluded system.
Where the status of a target is ambiguous, it is outside scope.

Type	Identifier	Basis for exclusion	Owner	Confirmed

4.1 Individuals excluded from social engineering

Identifier or group	Basis

Identifier or group

Basis

4.2 Periods of restriction

Period

Basis

APPENDIX 5 — AUTHORISED ACTIONS

Action

Conditions and limits

Approval level

1

2

3

4

5

6

7

8

APPENDIX 6 — PROHIBITED ACTIONS

The list at Annex B, paragraph B.5, applies in full. Its **absolute** prohibitions cannot be waived. Additional prohibitions for this engagement:

#	Prohibited action	Status: absolute / conditional	Basis
1			
2			
3			
4			
5			
6			

Conditional authorisations granted. An entry is valid only for an action classified as conditional, expressly permitted by applicable law and provider terms, and supported by the stated controls. Absolute prohibitions shall not appear here.

Action and exact limit	Safety controls and rollback	Legal / provider review	Risk accepted by	Date and expiry

APPENDIX 7 — OBJECTIVES AND SUCCESS CRITERIA

Objective ID	Objective	Success criteria	Evidence required	Marker placed	Location (Trusted Agent only)	Period
O-01				☐		
O-02				☐		
O-03				☐		

APPENDIX 8 — THREAT PROFILE

Attach the completed pro forma T03, or summarise:

Adversary

Motivation

Capability level

Initial access vectors emulated

Principal techniques

Techniques not emulated, and the basis

APPENDIX 9 — RECORD OF CHANGES

#	Requested (UTC) / by	Change and direction: restrict / expand / clarify	Basis, risk and affected boundary	Required authorities and permission refs	Effective (UTC)	Operators briefed (UTC)
1						
2						
3						
4						
5						
6						
7						
8						